

Rattrapage



UE 04

Produit et Storytelling

Promotion 2026

Auteur : **Younes Benaggoun**

A. Cartographie et conformité RGPD

A1. Cartographie des traitements

Traitement	Finalité	Données	Personnes	Destinataires	Durée
Compte & authentification	Créer, sécuriser et exploiter le compte	Email, nom, entreprise, date naissance, hash, session	Salariés, RH, coachs, admin	WellWork, prestataires techniques	Non définie précisément ; retentionDays=null
Questionnaire santé	Bien-être, suivi et personnalisation	Stress, poids, taille, sommeil, antécédents, traitements, tabac	Salariés	Coach / WellWork ; export possible	Non définie ; historique conservé
Messagerie	Échange coach/salarié	Identifiants, contenu des messages, dates	Salariés, coachs	Destinataire du message	Non définie
Annuaire RH	Recherche d'utilisateurs	Identité, email, entreprise, profil	Salariés	RH / utilisateurs authentifiés selon route	Non définie
Export assureur	Transmission au partenaire	Le code exporte l'intégralité du profil + questionnaires	Salariés	Assureur partenaire	Non définie
Marketing	Prospection / communication	Email et indicateur marketing	Utilisateurs	WellWork / partenaires selon usage	Non définie
Logs applicatifs	Support et diagnostic	Email, événements, identifiants et actuellement mots de passe	Utilisateurs	Équipe technique	Non définie

A2. Acteurs et responsabilités

Acteur	Qualification proposée	Justification
Entreprise cliente	Responsable de traitement pour ses propres finalités RH	Elle détermine pourquoi et comment certaines données de ses salariés sont utilisées dans son périmètre.
WellWork	Sous-traitant lorsqu'elle agit uniquement sur instruction de l'entreprise ; responsable pour ses propres finalités	La qualification dépend du contrat et des décisions réelles. La plateforme ne peut pas être déclarée automatiquement sous-traitante pour tous les traitements.
Assureur	Responsable distinct, ou responsables conjoints si les finalités sont déterminées ensemble	À vérifier dans les contrats, instructions, finalités et modalités de l'export.
Coach	Utilisateur autorisé / destinataire selon contrat	Accès limité au strict nécessaire, avec contrôle d'habilitation.

A3. Analyse d'impact AIPD

Conclusion : l'AIPD est à considérer comme obligatoire pour la plateforme en production si le traitement constitue une évaluation systématique/étendue des salariés ou un traitement à grande échelle de catégories particulières de données. Le seul jeu de démonstration de 63 comptes ne permet pas, à lui seul, de prouver le critère « grande échelle » ; le contexte réel de la start-up doit être documenté.

Traitement analysé

Questionnaires de santé, croisés avec le compte utilisateur et potentiellement consultables par des acteurs métier et exportés vers l'assureur.

Catégories : santé, habitudes de vie, identifiants, données professionnelles.

Risques principaux

- Accès non autorisé aux données de santé.
- Profilage ou interprétation des salariés.
- Transmission excessive à un assureur.
- Ré-identification et stigmatisation.
- Conservation excessive.

Risque	Vraisemblance	Impact	Niveau initial	Mesure	Résiduel cible
Lecture d'un questionnaire par un autre salarié	Forte	Très fort	Critique	RBAC/ABAC, contrôle d'appartenance, tests d'autorisation, journalisation des accès	Moyen
Fuite de mots de passe via logs	Forte	Fort	Critique	Suppression des secrets des logs, rotation, contrôle d'accès, secret scanning	Faible
Export excessif assureur	Moyenne	Très fort	Élevé	Data mapping, allow-list de champs, chiffrement, contrat, validation DPO	Faible/Moyen
Conservation indéfinie	Forte	Fort	Élevé	Politique de conservation, purge automatisée, preuve de suppression	Faible

A4. Constats de non-conformité RGPD

Constat	Article(s)	Preuve	Risque	Gravité
Consentement marketing pré-coché	Art. 5(1)(a), 6, 7	register crée marketingOptIn:true et un consentement marketing sans action utilisateur.	Prospection sans consentement démontré.	Élevée
Consentement tiers non spécifique	Art. 5(1)(a), 6, 7	thirdParty:true est enregistré automatiquement.	Transmission à un tiers sans choix granulaire.	Élevée
Données de santé trop largement accessibles	Art. 5(1)(c), 9, 25, 32	GET /api/users/:id renvoie le profil et tous les questionnaires à tout utilisateur authentifié.	Divulgaration de données sensibles entre utilisateurs.	Critique
Durées de conservation non définies	Art. 5(1)(e)	retentionDays:null et absence de purge.	Conservation indéfinie et accumulation de risque.	Élevée
Minimisation insuffisante de l'export assureur	Art. 5(1)(c), 6, 9, 28/30 selon rôles	users.map(...) ajoute le profil complet et les questionnaires.	Transmission excessive de données sensibles.	Critique
Transparence insuffisante dans l'interface	Art. 12–14	L'interface de démonstration collecte des réponses de santé sans information détaillée visible sur finalité, destinataires, conservation et droits.	Information incomplète au moment de la collecte.	Élevée

B. Audit de sécurité

B1. Constats techniques et scores CVSS

ID	Description / preuve reproductible	OWASP	CVSS v3.1 indicatif	Impact
S1	log('info','login_attempt',{email,password}) et même pratique sur register. Reproductible en appelant /api/login puis en consultant logs/app.log.	A09 — Security Logging and Monitoring Failures	9.1 AV:N/AC:L/PR:L/UI:N /S:U/C:H/I:H/A:N	Vol de comptes, réutilisation de mots de passe.
S2	sessionSecret, clé assureur et mot de passe SMTP présents dans src/config.js.	A05 — Security Misconfiguration	8.1 AV:N/AC:L/PR:L/UI:N /S:U/C:H/I:H/A:N	Compromission de services et propagation.
S3	crypto.createHash('sha256').update(password).digest('hex').	A02 — Cryptographic Failures	7.5 AV:N/AC:L/PR:N/UI:N /S:U/C:H/I:N/A:N	Attaques hors ligne accélérées sur les hashes.
S4	Jeton = base64 de user.id + seq + Date.now(), stocké sans expiration.	A07 — Identification and Authentication Failures	8.1 AV:N/AC:H/PR:N/UI:N /S:U/C:H/I:H/A:N	Usurpation si prédiction/obtention du token.
S5	GET /api/users/:id ne vérifie ni rôle ni appartenance avant de renvoyer questionnaires.	A01 — Broken Access Control	8.1 AV:N/AC:L/PR:L/UI:N /S:U/C:H/I:L/A:N	Lecture de données de santé d'un tiers.
S6	db.query('users', filter) puis new Function(...) exécute la chaîne fournie par le client.	A03 — Injection	9.8 AV:N/AC:L/PR:N/UI:N /S:U/C:H/I:H/A:H	Exécution de logique arbitraire dans le contexte Node.js, selon les primitives disponibles.
S7	cors() ouvre les origines à toutes les applications.	A05 — Security Misconfiguration	5.3 AV:N/AC:L/PR:N/UI:R /S:U/C:L/I:L/A:N	Augmente la surface d'attaque ; gravité dépendante du contexte navigateur/auth.
S8	Jeton accepté dans req.query.token.	A07 / A04	6.5 AV:N/AC:L/PR:N/UI:R /S:U/C:H/I:N/A:N	Fuite via URL, historique, logs ou referer selon architecture.

B2. Preuves clés dans le code

S1 — secrets dans les logs

```
src/routes/accounts.js

log('info', 'login_attempt', {
  email, password
});

log('info', 'register_attempt', {
  email, password, company
});
```

S2 — secrets codés en dur

```
src/config.js

sessionSecret: 'wellwork-prod-2024',
insurerApiKey: 'ins_live_...',
smtp: {
  user: 'noreply@...',
  pass: 'Sup3rMail!'
}
```

S3 — hash faible

```
src/db.js

crypto.createHash('sha256')
  .update(pwd)
  .digest('hex');
```

S4 — absence de contrôle d'objet

```
src/routes/data.js

router.get('/users/:id',
  requireAuth, (req, res) => {
    const u = db.query('users', ...)[0];
    const questionnaires =
      db.query('questionnaires', ...);
    res.json({ ...u, questionnaires });
  });
```

B3. Lien sécurité / violation de données

Hypothèse de fuite la plus crédible : la combinaison de S5 (accès horizontal aux utilisateurs/questionnaires), S1 (mots de passe dans les logs) et S6 (filtre exécuté par new Function) offre plusieurs chemins permettant l'accès ou l'exfiltration de données. Le fichier signalé sur un forum doit être comparé aux artefacts présents dans db/wellwork.json, aux logs et aux journaux réseau avant d'attribuer formellement la cause.

B4. Violation de données — articles 33 et 34

La présence d'un fichier contenant des données d'utilisateurs sur un forum constitue un **signal de violation de données personnelles** qui doit être qualifié immédiatement. Une notification à l'autorité de contrôle est requise lorsqu'il est probable que la violation présente un risque pour les droits et libertés, dans les meilleurs délais et si possible dans les 72 heures après en avoir pris connaissance. Si le risque est élevé, les personnes concernées doivent également être informées, sous réserve des exceptions prévues par le RGPD.

Actions immédiates

1. Geler et préserver les preuves.
2. Identifier exactement le fichier, sa provenance et sa date de diffusion.
3. Révoquer/rotater les secrets et sessions.
4. Déterminer les personnes et catégories de données concernées.
5. Évaluer le risque et documenter la décision.
6. Notifier la CNIL si les critères de l'article 33 sont remplis.

Critère de communication

La présence de données de santé, identifiants et potentiellement mots de passe fait pencher l'analyse vers un **risque élevée**. La communication aux personnes est donc à préparer, sans attendre si l'équipe conclut à un risque élevé.

B5. Notification à la CNIL

Objet : Notification de violation de données personnelles — WellWork

Responsable : [entité juridique / coordonnées DPO]

Date et heure de détection : [à compléter]

Date/heure estimée de la violation : [à compléter]

Nature : divulgation/exfiltration non autorisée de données d'utilisateurs.

Données concernées : données d'identité et de compte ; potentiellement données de santé issues des questionnaires ; autres catégories à confirmer par l'analyse forensique.

Nombre de personnes : [à confirmer à partir du fichier diffusé et de la base].

Origine suspectée : plusieurs vulnérabilités présentes dans l'application, notamment contrôle d'accès insuffisant, journalisation de secrets et exécution de filtres fournis par l'utilisateur.

Conséquences : accès ou divulgation non autorisés, risque de compromission de comptes et atteinte à la confidentialité des données de santé.

Mesures : désactivation des accès à risque, rotation des secrets, restriction des routes sensibles, conservation des preuves, correction du code, revue des habilitations et analyse des journaux.

Mesures prévues : authentification robuste, contrôle d'accès objet, gestion centralisée des secrets, minimisation des exports, politique de conservation et tests de sécurité.

B6. Message aux personnes concernées

Objet : Information importante concernant la sécurité de vos données WellWork

Nous vous informons qu'un incident de sécurité a affecté des données associées à votre compte WellWork. Notre analyse indique qu'un fichier contenant des données d'utilisateurs a été diffusé sur un espace public. Les catégories de données potentiellement concernées sont [à compléter précisément].

Dès la détection, nous avons engagé une investigation, sécurisé les accès concernés, renouvelé les secrets techniques et renforcé les contrôles d'accès. Si votre mot de passe peut être concerné, nous vous demandons de le modifier immédiatement et de ne pas réutiliser un mot de passe utilisé sur un autre service.

Nous vous indiquons également les mesures de protection que nous recommandons et les coordonnées de notre DPO pour toute question ou exercice de vos droits : [coordonnées].

C. Plan de remédiation

C1. Plan priorisé

Phase	Action	Constats	Responsable	Échéance	Preuve attendue
Immédiat	Révoquer toutes les sessions, remplacer les secrets, supprimer les mots de passe des logs et sécuriser les logs historiques.	S1,S2,S4	RSSI / Lead Dev	0–24 h	Secrets rotatés, logs nettoyés, sessions invalidées.
Immédiat	Restreindre /users/:id et suspendre l'export assureur jusqu'à revue.	S5, R1	Lead Dev / DPO	0–24 h	Tests 401/403 + export désactivé.
Immédiat	Supprimer le new Function et remplacer par une allow-list de filtres.	S6	Backend	0–48 h	Test d'injection négatif.
Court terme	Passer à Argon2id/bcrypt avec sel et politique de migration des comptes.	S3	Backend	S1	Tests hash + migration.
Court terme	Mettre en place RBAC/ABAC pour salarié, coach, RH, admin.	S5	Backend / DPO	S1–S2	Matrice d'habilitation et tests.
Court terme	Recueillir les consentements séparément et journaliser preuve, version, date et finalité.	R1	Produit / DPO	S2	Parcours UX + tests.
Structurel	Politique de conservation et purge automatisée par catégorie.	R4	DPO / Data	S3	Jobs de purge + rapport.
Structurel	Allow-list de l'export assureur, chiffrement, contrat et revue DPO.	R5	DPO / RSSI	S3	Schéma d'export minimal.
Structurel	CI sécurité : secret scanning, SAST, tests d'autorisation, dépendances.	S1–S8	DevOps	S3–S4	Pipeline bloquant sur findings critiques.

C2. Correctifs attendus sur branche dédiée

Le dépôt fourni ne contient pas, dans l'archive analysée, une branche de correctifs déjà réalisée. Pour rester factuel, cette section définit les **5 correctifs minimum à implémenter** et les preuves attendues ; elle ne prétend pas qu'ils ont déjà été appliqués.

Commit proposé	Correctif	Type	Non-régression
fix(security): redact credentials from logs	Supprimer password des événements login/register + tests.	Sécurité	Recherche automatisée de password dans les logs.
fix(security): replace executable user filters	Allow-list de filtres simples ; aucune exécution dynamique.	Sécurité	Payloads d'injection doivent retourner 400/403.
fix(security): enforce object authorization	Contrôle d'accès sur /users/:id.	Sécurité	Utilisateur A ne peut pas lire B.
fix(auth): use password hashing with salt	Argon2id/bcrypt et migration progressive.	Sécurité	Login valide + ancien hash refusé après migration.
fix(privacy): separate consent purposes	Marketing et tiers indépendants, non cochés par défaut.	RGPD	Tests API/UX sur consentement explicite.
fix(privacy): minimize insurer export	Exporter uniquement les champs validés juridiquement.	RGPD	Snapshot du schéma d'export.

D. Méthodologie Agile

D1. Équipe proposée

1. **Product Owner** Arbitre la valeur métier et le renouvellement du grand compte.
2. **Tech Lead / RSSI** Responsable de l'architecture, sécurité et acceptation des contrôles techniques.
3. **DPO** Valide les finalités, bases légales, AIPD, droits et conservation.

Équipe de 5 à 6 personnes : PO, Tech Lead/RSSI, 2 développeurs backend/full-stack, 1 DevSecOps, DPO à temps partiel. Ce format est adapté à une start-up : assez compact pour décider vite, mais avec une séparation explicite entre produit, sécurité et conformité.

D2. Backlog : epics, user stories et abuser stories

ID	Type	Story	Critères d'acceptation	Priorité
EP1-01	User	En tant qu'utilisateur, je veux que mon questionnaire ne soit visible que par les rôles autorisés.	Utilisateur A reçoit 403 pour les données de B ; coach/RH selon matrice.	P0
EP1-02	Abuser	En tant qu'attaquant authentifié, je tente d'énumérer les utilisateurs.	Les routes refusent les IDs non autorisés et ne divulguent pas de données sensibles.	P0
EP2-01	Abuser	Je tente d'injecter une expression dans filter.	Aucune chaîne utilisateur n'est exécutée ; payloads malveillants rejetés.	P0
EP2-02	User	Je veux une session difficile à voler.	Token aléatoire, expiration, révocation et rotation.	P0
EP3-01	User	Je veux donner séparément mon accord au marketing et aux tiers.	Aucun consentement pré-coché ; preuve versionnée et révocable.	P1
EP3-02	User	Je veux comprendre combien de temps mes données sont conservées.	Durées affichées par catégorie et purge démontrable.	P1
EP4-01	Abuser	Je recherche des secrets dans le dépôt et les logs.	Secret scanning sans findings critiques ; logs sans credentials.	P0
EP5-01	User	Je veux qu'un export assureur ne contienne que les données nécessaires.	Schéma d'export allow-listé et approuvé DPO.	P1

D3. Estimation et priorisation

Méthode retenue : **Risque × Valeur / Effort**, avec priorité P0 lorsque l'action réduit un risque de fuite de données de santé ou une compromission d'accès.

Item	Risque (1–5)	Valeur (1–5)	Effort (1–5)	Score
Contrôle d'accès objet	5	5	3	8,3
Suppression des secrets des logs	5	5	2	12,5
Suppression de new Function	5	5	3	8,3
Secrets manager	5	5	3	8,3
Consentements séparés	4	4	3	5,3
Conservation/purge	4	4	4	4

D4. Découpage en sprints

Sprint 0 1–2 j	Confinement. Rotation des secrets, invalidation sessions, blocage export, collecte des preuves et qualification de la fuite.
Sprint 1 1 sem.	Accès & authentification. RBAC/ABAC, contrôle objet, tokens aléatoires, expiration, hashing moderne.
Sprint 2 1 sem.	Données & consentements. Parcours de consentement, minimisation, politique de conservation, AIPD et information utilisateur.
Sprint 3 1 sem.	Export & DevSecOps. Export allow-listé, secret scanning, SAST, tests d'autorisation, dépendances et monitoring.

D5. Définition des Buts

- ✓ Code revu par un pair.
- ✓ Tests unitaires/intégration et tests négatifs d'autorisation.
- ✓ Aucun secret dans le dépôt, logs ou artefacts.
- ✓ Données personnelles minimisées et finalité documentée.
- ✓ DPO valide les changements affectant finalité, base légale, consentement, conservation ou destinataires.
- ✓ RSSI valide les changements à risque élevé.
- ✓ Preuve de non-régression jointe au ticket.

D6. Cérémonies, rôles et indicateurs

Élément	Cadence	But
Daily	Quotidien	Blocages et risques.
Planning	Début de sprint	Engagement sur capacité réelle.
Review	Fin de sprint	Démonstration des contrôles et preuves.
Rétrospective	Fin de sprint	Amélioration continue.
Comité sécurité/RGPD	Hebdomadaire	DPO + RSSI + PO : risques, décisions, exceptions.

KPI : nombre de findings critiques ouverts, délai moyen de correction, couverture des tests d'autorisation, secrets détectés, pourcentage de traitements avec base légale documentée, pourcentage de données avec durée de conservation définie, nombre d'exceptions de sécurité ouvertes.

E. Trame de restitution au comité de direction

0:00–1:00 — Situation

« WellWork traite des données personnelles dont certaines sont des données de santé. L'audit montre que le produit a grandi plus vite que ses contrôles de sécurité et de conformité. Une fuite sur un forum rend le sujet immédiat. »

1:00–2:00 — Risques

« Les risques prioritaires sont l'accès non autorisé aux questionnaires, la fuite de mots de passe par les logs, les secrets techniques présents dans le code et un mécanisme d'injection permettant de contrôler une expression exécutée côté serveur. À cela s'ajoutent des problèmes de consentement, de conservation et de minimisation. »

2:00–3:00 — Plan

« Nous confignons d'abord : rotation des secrets, révocation des sessions, blocage des exports et préservation des preuves. Ensuite, nous sécurisons les accès et l'authentification. Enfin, nous industrialisons la conformité : consentements, conservation, AIPD, export minimal et contrôles CI. »

3:00–4:00 — Budget et capacité

Hypothèse de pilotage : 5–6 personnes pendant environ 3 à 4 semaines, avec DPO et RSSI impliqués à chaque décision sensible. Le budget doit être validé sur la base du coût interne/jour et des éventuels outils de secret management, SAST, monitoring et accompagnement juridique.

4:00–5:00 — Décisions demandées

1. Autoriser le confinement immédiat et la rotation des secrets.
2. Autoriser la suspension temporaire de l'export assureur.
3. Nommer un propriétaire de risque côté direction.
4. Valider l'équipe de remédiation et les 4 sprints.
5. Donner mandat au DPO/RSSI pour qualifier la violation et décider des notifications.

Annexe — Transparence IA

Une IA générative a été utilisée comme outil d'assistance à la structuration et à la rédaction du livrable. Détection et corrections des fautes d'orthographe,

Usage de l'IA :

- Structuration du rapport et reformulation
- Identification de constats de sécurité à partir du code
- Proposition de correspondances RGPD/OWASP/CVSS
- Rédaction de la notification et du plan agile